

Secure Network Design: Merger Company A & Company B

Kresha Felder, BSN, RN

College of Information Security/Western Governors University

Instructor: Bob Curtis

April 14, 2026

A: Business Requirements

Company A: Assessment of Security and Infrastructure

- Security Problem 1: Weak Access Controls. My risk analysis found that all users are limited to 8-character passwords. From a security standpoint, it is far too easy to bypass with basic hacking tools.
- Security Problem 2: Excessive Administrative Rights. Currently, every employee has local admin privileges on their computers. This is a major concern because it allows any user to accidentally install malicious software that could compromise the entire financial database.
- Infrastructure Problem 1: Obsolete Hardware (Windows 7). There are 14 laptops still running Windows 7. Since this OS no longer receives safety patches, these devices are like expired equipment that should no longer be used in a professional clinical or financial environment.
- Infrastructure Problem 2: Aging Network Cabling. Company A uses Cat5e cabling. While this worked in the past, it doesn't have the capacity we need to quickly move large amounts of data to the Cloud as we merge these two companies.

Company B: Assessment of Security and Infrastructure

- Security Problem 1: Use of Insecure Plain Text Communication. The vulnerability report shows rsh and rlogin are active. In a B2B environment, these are dangerous because they allow an attacker to intercept the administrative credentials used to manage the software

platform. Because these protocols transmit credentials in plain text, any attacker on the local network could use a packet sniffer to capture administrative logins.

- Security Problem 2: Critical Backdoor Vulnerabilities. The Apache Tomcat and dRuby vulnerabilities are critical flaws in the engines that run their medical software. Because they provide this software to other providers, these flaws could be exploited to simultaneously steal data from multiple medical practices.
- Infrastructure Problem 1: Home-Grade Router. The Verizon home is not sufficient to protect a software-as-a-service platform. It lacks the security needed to protect the hosted medical applications from modern internet threats, failing to meet the Standard of Care expected of a medical software vendor.
- Infrastructure Problem 2: Lack of Internal Borders (Segmentation). Without managed switches, there is no way to separate the software development environment from the production environment where real medical data lives. This lack of isolation means a simple error in one area could expose sensitive records across the entire platform.

B1: Vulnerabilities

Company A (Financial)

- Problem 1: Weak Entry Requirements. The 8-character password limit is a major security gap. In the financial industry, we need stronger locks. Because these passwords are so short, a hacker's computer can try thousands of guesses a second until it finds the right one. This puts our customers' checking and investment accounts at immediate risk of unauthorized access.

- Problem 2: Expired Operating Systems. The 14 Windows 7 laptops are like expired medical supplies. The manufacturer (Microsoft) no longer provides the security updates needed to keep them safe. This means that if a new type of digital infection emerges tomorrow, these laptops have no way to defend themselves, leaving them a permanent weak point in our network.

Company B (B2B Medical Software Provider)

- Problem 1: Unprotected Communication. Using rsh and rlogin means the server's keys are sent across the network, where anyone can read them. It is essentially shouting passwords across a room. Since Company B provides software to medical doctors, an attacker who overhears these passwords could take over the entire software platform and see every patient record stored there. Because rsh and rlogin do not use encryption, administrative credentials can be captured via a Man-in-the-Middle attack, leading to full system compromise.
- Problem 2: Basic Home-Grade Protection. The Verizon FIOS router is designed for a house, not a medical software company. It doesn't have the intelligence to scan incoming data for hidden threats. It simply follows basic To/From instructions, which isn't enough to protect sensitive HIPAA-regulated data from a targeted attack.

B2: Impact, Risk, Likelihood

1. Company A: Weak Password Policy

- Assessment: The use of 8-character passwords is below industry standards.

- Likelihood: High. Brute-force tools can crack an 8-character password in minutes or hours.
- Risk/Impact: High. When a finance employee's login is stolen, the safety of the entire organization's capital is at stake. An attacker with these credentials doesn't just see numbers; they can move through checking accounts and credit card databases. We aren't just talking about a one-time theft here. The aftershock includes heavy fines from regulators and reputational damage that most firms never fully recover from. For a financial entity, this isn't just a technical glitch; it's a catastrophic failure of trust.

2. Company A: End-Of-Life Windows 7 Laptops

- Assessment: These 14 devices are no longer supported by the manufacturer (Microsoft) for safety patches.
- Likelihood: Medium to High. Hackers specifically target older operating systems because they know the vulnerabilities are well- documented and will never be fixed.
- Risk/Impact: High. Leaving these laptops on the network is a direct liability. Since they no longer receive security updates, they serve as unsterilized entry points that bypass modern defenses. If even one unit is compromised, an attacker isn't confined to that single device. They can pivot and move laterally through the internal network to reach our critical Windows 10 and 11 workstations. In this scenario, the 'herd immunity' of our newer systems is negated because they are connected to an actively infected and unpatchable source. According to Landoll (2021), unsupported hardware represents a critical vulnerability because the manufacturer no longer provides the security patches needed to address new exploits.

3. Company B: Insecure Clear Text Protocols

- **Assessment:** Reliance on rsh and rlogin for server management is a critical oversight. These protocols transmit data in clear text, meaning they lack the encryption found in modern tools like SSH.
- **Likelihood:** High. In a real-world scenario, such as a guest sitting on the office Wi-Fi, an attacker can simply sniff the network traffic. Because there is no encryption, administrative passwords appear in plain sight. It effectively hands the hospital's keys to anyone with basic packet-sniffing software, making a credential breach almost certain if an intruder gains local access.
- **Risk/Impact:** Critical. Since this is B2B software, a stolen admin password gives the hacker total control over the servers hosting the medical software. This compromises the privacy of every medical provider using the system.

4. Company B: Consumer-Grade Router

- **Assessment:** Using a Verizon home router to protect a software company.
- **Likelihood:** Medium. It lacks intrusion detection to detect sophisticated attacks.
- **Risk/Impact:** High. It fails to meet the regulatory standard of care required for HIPAA and PCI. It leaves the company's internal servers and the medical data they hold vulnerable to discovery on the internet.

C: Topology Diagram (See Diagram)

While I was planning the merger, I moved away from the fragmented legacy setups and implemented Hub-and-Spoke architecture with a secure Cloud core. This shift isn't just about

modernizing, it's about creating a single, manageable point of control. By pulling our critical resources into this Cloud Hub, we can decommission the aging hardware at Site A and keep sensitive data isolated from general office traffic. Most importantly, this structure allows us to enforce a Zero Trust model, ensuring that every connection, whether it's from the main office or a remote site, is verified before any data is exchanged.

1. The Central Hub: Azure Cloud Consolidation

Instead of trying to fix the old, broken servers at both companies, I have moved the four most critical roles (Identity, File Sharing, Applications, and Email) into the Azure Cloud.

- The Benefit: The on-premises sites connect to the Azure hub via encrypted site-to-site VPN tunnels, ensuring all data in transit is protected from interception. By moving these to the Cloud, we can ensure they are always patched and backed up, thereby resolving the expired equipment issue we found at both sites. It also allows the medical software from Company B to scale up as they get more providers.

2. The Spokes: Site-Specific Security Enhancements

Company A (Financial): I elected to retain the FortiGate 800D Firewall, as its hardware specifications still meet enterprise-grade requirements for this merger. The critical change I implemented was configuring a dedicated DMZ for the Web Server. This creates a necessary "air gap" at the network layer. If the Web Server is hit with an exploit, the DMZ restricts the blast radius, effectively blocking lateral movement into the financial database or employee workstations.

- Company B (Medical Software): My primary focus here was remediating the lack of enterprise controls. I replaced the existing consumer-grade router with a Sophos XG

Firewall to allow for deep packet inspection. Furthermore, I swapped the unmanaged hardware for Aruba Stacked Managed Switches. This allows us to enforce strict VLAN segmentation. By separating medical application data from the guest Wi-Fi at the hardware level, we ensure that external traffic has no logical path to sensitive healthcare records (InfoSec Learning, 2022).

- The Lock Icons: On my diagram, the locks represent Multi-Factor Authentication and identity checks.
- Continuous Verification: Even though Company A and Company B are now one company, the network does not trust them. Every time an employee tries to access Cloud Servers, they must pass through the Virtual Network Gateway, where their identity is verified. No one gets a free pass just because they are inside the building.

4. Regulatory Compliance (HIPAA and PCI-DSS)

This design was built to satisfy the Standard of Care for both the financial and medical industries.

- PCI-DSS: By using managed switches and firewalls, we isolate the credit card transaction traffic from the rest of the office.
- HIPAA: By moving the medical software to the Cloud and using encrypted VPN tunnels (the dashed lines on my diagram), we ensure that patient data is never sent over the internet in clear text, where it could be compromised.

D: Topology Components

Device	OSI Layer	TCP/IP Layer
Fortigate 800D & Sophos XGS 126 Firewalls	Layer 7 - Application	Application
Cisco 7600 Router	Layer 3 - Network	Internet
Cloud Servers (Identity, File, App, Email)	Layer 7 - Application	Application
Cisco 3750X & Aruba Stacked Switches	Layer 2 - Data Link	Network Access
Meraki & Aruba Wireless Access Points	Layer 2 - Data Link	Network Access
Workstations & Lenovo ThinkPad Laptops	Layer 7 - Application	Application
Pooled Printers & MFP/Copier	Layer 7 - Application	Application
Remote Access VPN Tunnels (SSL/TLS)	Layer 4 - Transport	Transport
VLAN's	Layer 2	Network Access
Cat6a Cabling	Layer 1 - Physical	Network Access

E: Rationale

1. Purchased Items

- **Azure Cloud Subscription:** We are purchasing the 4 server roles (Identity, SharePoint, App, Exchange). Cloud hosting costs were estimated using the Microsoft Azure Pricing Calculator (2026) for four D-Series virtual machines to ensure high availability for medical software hosting.
 - *Why:* To replace the end-of-life on-premises hardware and provide the scalability the executives asked for.
 - *Estimated Price:* Roughly \$8,000 - \$12,000/year for standard B-series or D-series virtual machines.

- Sophos XGS 126 Firewall: I specifically selected the Sophos XG for Company B because the interface is intuitive for a smaller staff, and it provides the robust deep packet inspection that their old consumer router lacked. A Sophos XGS 126 firewall was selected at a projected cost of \$1,780, which includes a one-year Xstream Protection Subscription for advanced threat detection (Corporate Armor, 2024).
 - *Why:* It provides the enterprise-level security required for a medical software vendor.
 - *Estimated Price:* \$1,750 (including a 1-year security subscription).
- New Laptops (to replace 14 Windows 7 units): The end-of-life Windows 7 laptops will be replaced with enterprise-grade Lenovo ThinkPad E16 units to ensure hardware-level encryption and compatibility with modern security patches (Best Buy, n.d.).
 - *Why:* You cannot patch out-of-date hardware. Replacing these is a critical security requirement.
 - *Estimated Price:* 14 units at \$1,000 each = \$14,000.

2. Repurposed Items

- Cisco 3750X Switches & Fortigate 800D (Company A):
 - These are enterprise-grade devices. Buying new versions would cost \$20,000+. By keeping them, we stay under budget while maintaining high security.
- Aruba AP-535 WAPs (Company B):
 - These are modern, high-speed access points. There is no reason to replace them; we simply moved them behind a better firewall.

3. Retained Items

- Cabling (Cat6a):
 - Moving Site A to a Cloud-heavy model meant I had to address the aging Cat5e wiring. While it still technically works, Cat5e is the clogged artery of this network; it creates a bottleneck for the constant cloud syncing and high-speed financial traffic we expect after the merger. I prioritized \$7,500 for a targeted Cat6A upgrade at the financial office. This investment doesn't just improve speed; it stabilizes our physical circulatory system and ensures Site A finally meets the same enterprise infrastructure standards already in place at Site B. This prevents a scenario where cheap, outdated copper throttles expensive Cloud servers.

F: Secure Network Design Principles

- Least Privilege Application: My design focuses on minimizing the blast radius of a potential breach by strictly enforcing the Principle of Least Privilege. This began with removing local administrative rights for all users; staff members now operate with only the permissions required for their roles. This transition is a critical control against accidental malware execution (Saltzer & Schroeder, 1975). Furthermore, I configured the Site-to-Site VPN with AES-256 encryption and multi-factor authentication (MFA) to ensure the medical database is accessible only to verified, authorized personnel.
- Transitioning to Zero Trust: I've moved the organization away from the 'trusted internal network' mindset. By implementing MFA at the Virtual Network Gateway, we've established that the network does not inherently trust a device just because the employee is physically on-site. This follows the NIST Zero Trust Architecture, which dictates that

network location must never imply trust (Rose et al., 2020). The use of VLANs to isolate medical traffic further reinforces this, ensuring that every access request is verified at the segment level.

- **Defense in Depth Strategy:** Instead of relying on a single front-door lock, I implemented a layered defense strategy. We are now protected by Sophos and FortiGate firewalls at the perimeter, but we don't stop there. Internal segmentation via VLANs and MFA for application access provides backup layers of protection. This 'fail-safe' approach ensures that if a single control is bypassed, such as an employee accidentally leaking a password, the attacker is trapped by the next security layer rather than gaining full access.

G: Regulatory Compliance

According to GRC Solutions (2025), two of the most common compliance regulations are HIPAA (Health Insurance Portability and Accountability Act) and PCI-DSS (Payment Card Industry Data Security Standard). Since Company B is a B2B medical software, and Company A is in finance:

- **HIPAA Security Rule:** Since Company B operates as a Business Associate that handles protected health information, HIPAA compliance was a primary driver of my design. To meet the Technical Safeguards for data in motion, I replaced all clear-text communication paths with encrypted VPN tunnels. By enforcing AES-256 encryption between the offices and the Cloud, we ensure that PHI remains unreadable to unauthorized parties during transit, satisfying the HIPAA requirement for secure electronic transmission.

- PCI-DSS Compliance: Because both entities process credit card payments, protecting the Cardholder Data Environment was non-negotiable. I utilized VLAN-based segmentation to logically isolate the payment processing traffic from the general office network.

H: Emerging Threats

Since we are merging a financial firm and a medical software provider, we have some unique predators to watch out for. Security oversights during the integration phase of a merger can lead to significant data exposure (The Hacker News, 2021).

1. The Insider Threat (During the Merger)

- The Situation: Mergers often create anxiety about job security.
- The Threat: A disgruntled employee at Company B, knowing they are being absorbed and their consumer-grade router is being replaced, might attempt to exfiltrate sensitive medical software code or patient data before they lose access.
- Relationship to Vulnerability: This threat exploits the Lack of Least Privilege (everyone having admin rights) we identified in Part A.

2. Ransomware/External Attackers (After the Merger)

- The Situation: Hackers monitor news for acquisitions. They know that during a merger, IT teams are distracted and security is often in flux.
- The Threat: An external group might target the Windows 7 laptops we identified. The presence of unsupported operating systems like Windows 7 creates a significant 'vulnerability debt' that cannot be mitigated by software patches, leaving the organization

exposed to known exploits (Landoll, 2021). Our automated Azure backups ensure that even if a ransomware attack occurs, we can restore the data without paying the ransom.

- Relationship to Vulnerability: This threat exploits End-of-Life Operating Systems and the fact that we haven't completed the full migration to the Cloud yet.

3. Data Breach via Sniffing (During the Merger)

- The Situation: As we move data between the two sites to integrate the databases.
- The Threat: Because Company B uses clear-text protocols (rsh), an attacker who has already compromised a guest's laptop on Wi-Fi could overhear the administrative credentials as they are typed.
- Relationship to Vulnerability: This threat directly exploits the Insecure Communication Protocols we found in the vulnerability report.

I: Summary Recommendations

1. Meeting the Scenario and Budget

The project was completed within the \$50,000 first-year budget provided by the executives. By prioritizing the replacement of end-of-life assets and moving critical services to a scalable Cloud environment, we transformed a high-risk merger into a secure, unified network.

2. Financial Breakdown (Direct Costs)

Item	Purpose	Estimated Cost
Azure Cloud Services	Hosting Identity, File, App, and Email servers.	\$12,000
Sophos XGs 126 Firewall	Replacing Company B's consumer router for HIPAA compliance.	\$1,780
Cat6A Cabling	Upgrading Company A cabling to match Company B.	\$7,500
14 New Laptops	Replacing the unpatchable Windows 7 units at Company A.	\$14,000
Azure VPN Gateway	Licensing for Zero Trust / MFA connectivity.	\$2,000
Implementation Labor	Contracted support for the Cloud migration.	\$10,000
TOTAL SPEND		\$47,280
Remaining Budget	Retained for emergency contingency.	\$2,720

3. Indirect Costs

Indirect costs are the hidden costs, such as Employee Downtime.

- Training: Time spent training Company B staff on the new Sophos and Azure environments.
- Productivity Loss: Brief periods of Read-Only access during the weekend data migration to the Cloud.

4. The CBA: Pros and Cons

The Pros:

- **Regulatory Avoidance:** A single HIPAA or PCI-DSS fine can exceed \$50,000. This design mitigates that risk entirely.
- **Scalability:** As Company B adds more medical providers, we can increase Cloud capacity with a click rather than buying new physical servers.
- **Repurposing Savings:** By reusing the FortiGate and Cisco gear, we avoided roughly \$30,000 in unnecessary hardware costs.

The Cons:

- **Recurring Costs:** Unlike physical hardware, the Azure Cloud requires a monthly subscription **fee**.
- **Internet Dependency:** If the main internet line goes down, access to Cloud servers is **limited**.

Citations

Best Buy. (n.d.). *Lenovo ThinkPad E16 Gen 1 16" laptop i7 1355U with 16GB memory 512GB SSD black 21JN0073US*. Retrieved April 14, 2026, from <https://www.bestbuy.com/product/lenovo-thinkpad-e16-gen-1-16-laptop-i7-1355u-with-16gb-memory-512gb-ssd-black/JJGYJ5R78G>

Corporate Armor. (2024). *Sophos XGS 116/126 next-gen firewall pricing*.
<https://www.corporatearmor.com/sophos-xgs-116-next-gen-firewall/>

GRC Solutions. (2025). *Compliance standards and regulations*.
<http://grcsolutions.io/compliance/>

InfoSec Learning, Inc. (2022). *HTMLEi vulnerability and mitigation* [Lab].
<https://lab.infoseclearning.com/lti?course=MBMQ9P65DP&lab=RUSYJMQTNO>

Landoll, D. J. (2021). *The security risk assessment handbook: A complete guide for performing IT security audits*. CRC Press.

Microsoft. (n.d.). *Pricing calculator* | Microsoft Azure. Retrieved April 2, 2026, from <https://azure.microsoft.com/en-us/pricing/calculator/>

The Hacker News. (2021, November). *The importance of IT security in your merger acquisition*. Retrieved April 7, 2026, from <https://thehackernews.com/2021/11/the-importance-of-it-security-in-your.html>

Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero trust architecture* (NIST Special Publication 800-207). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-207>

Saltzer, J. H., & Schroeder, M. D. (1975). The protection of information in computer systems.

Proceedings of the IEEE, 63(9), 1278-1308.